Executive Summary

NovaPay Fintech Ltd engaged in a SOC 2 readiness assessment to evaluate its current control environment against the Trust Services Criteria established by the American Institute of Certified Public Accountants.

The assessment identified several strengths, including basic access controls and encryption mechanisms. However, key gaps were observed in areas such as multi-factor authentication, centralized logging, incident response and privacy governance.

These gaps expose the organization to elevated security and compliance risks. This report provides actionable recommendations to enhance control effectiveness and improve readiness for a future SOC 2 audit.

Introduction

SOC 2 is a widely recognized framework used to assess an organization's controls related to security, availability, confidentiality, processing integrity and privacy.

This readiness assessment evaluates NovaPay's existing controls and identifies gaps that must be addressed before undergoing a formal SOC 2 audit.

Scope

This assessment focuses primarily on the Security Trust Services Criteria, with additional consideration given to Availability, Confidentiality and Privacy controls across NovaPay's systems and processes.

Methodology

The assessment was conducted using a structured approach, including:

- Review of existing policies and procedures
- Evaluation of implemented controls
- Mapping controls to SOC 2 Trust Services Criteria
- Identification of control gaps
- Risk-based analysis of deficiencies

Assessment Findings

The assessment identified the following key gaps:

- Absence of Multi-Factor Authentication (MFA)
- Lack of centralized logging and monitoring
- No formal incident response plan
- Incomplete security policies
- Lack of defined privacy framework

Risk Analysis

The identified gaps were assessed based on their potential impact and likelihood.

High-risk issues were primarily related to access control weaknesses and lack of monitoring, which could lead to unauthorized access and delayed incident detection.

Medium-risk issues included incomplete policy frameworks and limited automation in monitoring processes.

Low-risk areas were associated with controls that are already partially implemented.

Recommendations

To improve SOC 2 readiness, NovaPay should:

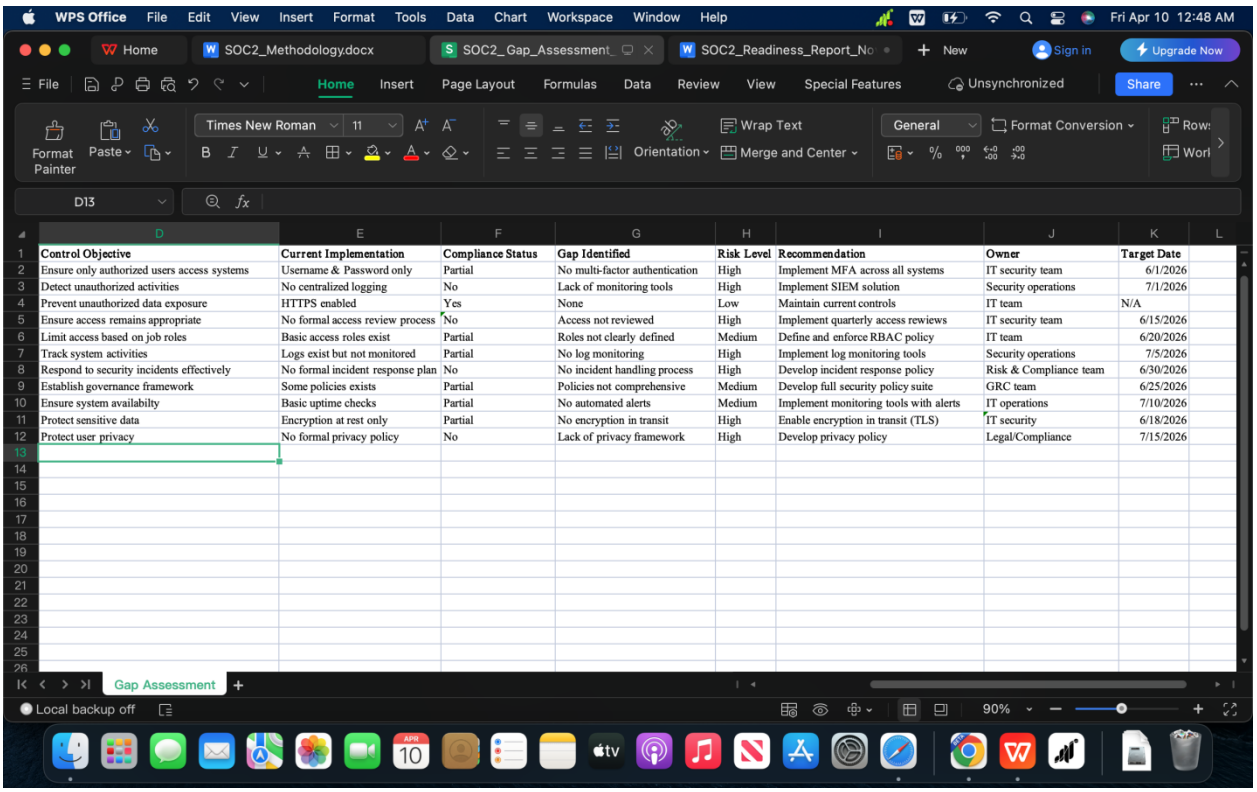
- Implement Multi-Factor Authentication (MFA) across all systems
- Deploy centralized logging and monitoring solutions (SIEM)
- Develop and implement an incident response plan
- Establish a comprehensive security policy framework
- Implement data encryption in transit
- Develop and enforce a privacy policy

Conclusion

NovaPay has taken initial steps toward establishing a secure control environment. However, several critical gaps must be addressed to achieve SOC 2 compliance readiness.

By implementing the recommended controls, the organization can significantly strengthen its security posture and improve its ability to successfully undergo a SOC 2 audit.

Figure 1: SOC2 Gap Assessment Overview



Control Objective	Current Implementation	Compliance Status	Gap Identified	Risk Level	Recommendation	Owner	Target Date
Ensure only authorized users access systems	Username & Password only	Partial	No multi-factor authentication	High	Implement MFA across all systems	IT security team	6/1/2026
Detect unauthorized activities	No centralized logging	No	Lack of monitoring tools	High	Implement SIEM solution	Security operations	7/1/2026
Prevent unauthorized data exposure	HTTPS enabled	Yes	None	Low	Maintain current controls	IT team	N/A
Ensure access remains appropriate	No formal access review process	No	Access not reviewed	High	Implement quarterly access rewiews	IT security team	6/15/2026
Limit access based on job roles	Basic access roles exist	Partial	Roles not clearly defined	Medium	Define and enforce RBAC policy	IT team	6/20/2026
Track system activities	Logs exist but not monitored	Partial	No log monitoring	High	Implement log monitoring tools	Security operations	7/5/2026
Respond to security incidents effectively	No formal incident response plan	No	No incident handling process	High	Develop incident response policy	Risk & Compliance team	6/30/2026
Establish governance framework	Some policies exists	Partial	Policies not comprehensive	Medium	Develop full security policy suite	GRC team	6/25/2026
Ensure system availabilty	Basic uptime checks	Partial	No automated alerts	Medium	Implement monitoring tools with alerts	IT operations	7/10/2026
Protect sensitive data	Encryption at rest only	Partial	No encryption in transit	High	Enable encryption in transit (TLS)	IT security	6/18/2026
Protect user privacy	No formal privacy policy	No	Lack of privacy framework	High	Develop privacy policy	Legal/Compliance	7/15/2026